

Encuesta Integral de Madurez MITRE ATT&CK

Versión: 1.0

Ámbito: Organizaciones españolas / internacionales

Marco de referencia: MITRE ATT&CK (Enterprise) y tendencias 2025–2026[web:3][web:29][web:66]

Objetivo: averiguar, con elegancia socrática y cierta sorna bienintencionada, hasta qué punto su organización ha dejado de ver la matriz MITRE ATT&CK como póster decorativo y la usa como instrumento de gobierno, detección y medición del riesgo.

1. Datos generales de la organización

1.1 Tipo de organización

- ☐ Administración pública
- ☐ Empresa privada – gran empresa
- ☐ Empresa privada – pyme
- ☐ Entidad sin ánimo de lucro
- ☐ Centro educativo / universidad
- ☐ Otro (especificar): ____

1.2 Sector principal

- ☐ Energía / Utilities
- ☐ Salud / Farma
- ☐ Financiero / Seguros
- ☐ Industria / Fabricación / OT
- ☐ TIC / Telecomunicaciones
- ☐ Transporte / Logística
- ☐ Administración pública
- ☐ Educación / Investigación
- ☐ Digital / Cloud / SaaS
- ☐ Otro (especificar): ____

1.3 Tamaño aproximado

- ☐ < 50 personas
- ☐ 50–249 personas
- ☐ 250–999 personas
- ☐ ≥ 1 000 personas

1.4 Ámbito geográfico

- ☐ Sólo ámbito nacional
- ☐ Nacional con algunas operaciones internacionales
- ☐ Multinacional

1.5 Figura que responde la encuesta

- ☐ CISO / Responsable de Seguridad
- ☐ CIO / Responsable de Sistemas
- ☐ Responsable de SOC / Detección
- ☐ Responsable de Riesgos / Cumplimiento
- ☐ Dirección General
- ☐ Otro (especificar): ____

2. Escala de madurez

Para la mayor parte de las preguntas se emplea:

- 0 – No aplica: no es relevante para nuestro entorno (prometemos que lo hemos pensado).
- 1 – No implementado: sabemos que existe, pero aquí no ha llegado.
- 2 – Inicial / ad-hoc: hay esfuerzos puntuales, pilotos o héroes solitarios.
- 3 – Definido: existe proceso definido y se usa, con alguna variación local.
- 4 – Gestionado / medido: se aplica sistemáticamente y hay indicadores.
- 5 – Optimizado: mejoramos a partir de resultados, incidentes y cambios de amenaza.

3. Gobierno y estrategia MITRE ATT&CK

3.1 Adopción estratégica del marco

G1. ¿En qué medida la dirección conoce y respalda el uso de MITRE ATT&CK en la organización?

- ☐ 0 – No aplica
- ☐ 1 – Desconocido: “¿MITRE qué?”
- ☐ 2 – Sólo el equipo técnico lo maneja
- ☐ 3 – La dirección ha oído hablar y lo menciona ocasionalmente
- ☐ 4 – Está incorporado en la estrategia de ciberseguridad
- ☐ 5 – Es un eje explícito del gobierno del riesgo y las inversiones

G2. ¿Existe una política o directriz formal que establezca el uso de MITRE ATT&CK como marco de referencia para detección y respuesta?

- ☐ 0
- ☐ 1 – No existe
- ☐ 2 – Práctica informal, “porque al SOC le gusta”
- ☐ 3 – Directriz básica incluida en políticas de seguridad
- ☐ 4 – Política formal aprobada, con ámbitos, roles y alcances definidos
- ☐ 5 – Política revisada regularmente y alineada con CTI, SOC y gestión de riesgos

G3. ¿Se emplea ATT&CK para priorizar casos de uso de seguridad (detecciones, alertas, dashboards)?

- ☐ 0
- ☐ 1 – No, priorizamos por “sensaciones”
- ☐ 2 – Se utiliza puntualmente en algunos proyectos
- ☐ 3 – Se usa sistemáticamente en el SOC para priorizar reglas

- [] 4 – Se vincula a análisis de riesgo y amenazas sectoriales (ENISA, CERT, etc.)[web:66][web:43]
- [] 5 – Es la base principal de priorización junto con el riesgo de negocio

G4. ¿Con qué frecuencia se informa a la alta dirección sobre la “cobertura ATT&CK” de la organización?

- [] 0
- [] 1 – Nunca
- [] 2 – Sólo tras incidentes relevantes
- [] 3 – Al menos una vez al año
- [] 4 – Trimestralmente
- [] 5 – Mensual o más frecuente, integrado en los KPIs del Consejo

4. Cobertura de tácticas y técnicas

4.1 Cobertura declarada (self-assessment)

C1. ¿Dispone la organización de un inventario formal que indique qué tácticas ATT&CK están cubiertas por alguna forma de detección?

- [] 0
- [] 1 – No
- [] 2 – Inventario parcial o no actualizado
- [] 3 – Inventario completo a nivel de táctica
- [] 4 – Inventario completo, con nivel de técnica principal
- [] 5 – Inventario completo hasta subtécnica y controles asociados

C2. ¿Qué nivel aproximado de cobertura de tácticas ATT&CK estima que tiene (detección básica)?

- [] 0 – No aplica / no sabemos
- [] 1 – < 25 % de las tácticas relevantes
- [] 2 – 25–49 %
- [] 3 – 50–74 %
- [] 4 – 75–89 %
- [] 5 – ≥ 90 % de las tácticas relevantes están cubiertas

C3. ¿Qué nivel aproximado de cobertura de técnicas ATT&CK relevantes estima que tiene (detección con al menos una alerta posible por técnica)?

- [] 0 – No aplica / desconocido
- [] 1 – < 20 %
- [] 2 – 20–39 %
- [] 3 – 40–59 %
- [] 4 – 60–79 %
- [] 5 – ≥ 80 %

4.2 Cobertura validada

C4. ¿Ha realizado la organización ejercicios específicos para validar la cobertura ATT&CK (purple teaming, emulación de adversarios, etc.)?[web:16][web:22][web:64]

- ☐ 0
- ☐ 1 – Nunca
- ☐ 2 – Algún ejercicio aislado
- ☐ 3 – Ejercicios anuales con cobertura ATT&CK documentada
- ☐ 4 – Programa regular (≥ 2 veces/año) con mapeo ATT&CK y mejora asociada
- ☐ 5 – Programa continuo con automatización y reporting de cobertura por técnica

C5. ¿Utilizan resultados de evaluaciones de proveedores basadas en MITRE ATT&CK (p. ej. Enterprise Evaluations 2025) para comparar soluciones?[web:16][web:22][web:59][web:64]

- ☐ 0
- ☐ 1 – No
- ☐ 2 – Excepcionalmente en alguna licitación
- ☐ 3 – Es un criterio habitual en la evaluación de EDR/XDR/SIEM
- ☐ 4 – Se integra formalmente en el scoring de selección de tecnologías
- ☐ 5 – Se revisa anualmente para ajustar arquitectura y roadmap de controles

C6. ¿La organización mide la diferencia entre cobertura “declarada” y cobertura “real” tras ejercicios y pruebas?

- ☐ 0
- ☐ 1 – No se compara
- ☐ 2 – Se compara de forma manual y puntual
- ☐ 3 – Se realiza revisión al menos anual
- ☐ 4 – Se rastrean brechas por táctica/técnica y se integran en el plan de mejora
- ☐ 5 – Se dispone de panel automático con desviaciones de cobertura y estado de corrección

5. Calidad de la detección y señal-ruido

Q1. ¿Cómo describiría la calidad de las detecciones mapeadas a ATT&CK (falsos positivos, contexto técnico, accionabilidad)?[web:16][web:22][web:60]

- ☐ 0 – No aplica / no medimos
- ☐ 1 – Detecciones ruidosas, de poca confianza
- ☐ 2 – Detecciones útiles pero con alto ruido
- ☐ 3 – Equilibrio razonable entre cobertura y ruido
- ☐ 4 – Alta calidad, con falsos positivos reducidos y buen contexto
- ☐ 5 – Muy alta calidad, con priorización clara y falsos positivos mínimos

Q2. ¿Se miden explícitamente falsos positivos relacionados con detecciones etiquetadas con ATT&CK?

- ☐ 0
- ☐ 1 – No
- ☐ 2 – Recuento informal, según sensación del analista
- ☐ 3 – Métricas básicas (tasa de falsos positivos por regla o caso de uso)
- ☐ 4 – Métricas detalladas agrupadas por táctica/técnica
- ☐ 5 – Métricas integradas con decisiones de tuning y roadmap de detección

Q3. ¿Se utiliza ATT&CK para racionalizar reglas redundantes y reducir el volumen de alertas?

- ☐ 0
- ☐ 1 – No
- ☐ 2 – De forma reactiva tras incidentes de “alert fatigue”
- ☐ 3 – Periódicamente como parte del mantenimiento del SIEM/XDR
- ☐ 4 – Con revisiones programadas basadas en datos de falsos positivos
- ☐ 5 – Como parte de un programa formal de ingeniería de detecciones

Q4. ¿Qué porcentaje aproximado de alertas de alto impacto están etiquetadas con técnicas ATT&CK?

- ☐ 0 – No sabemos
- ☐ 1 – < 20 %
- ☐ 2 – 20–39 %
- ☐ 3 – 40–59 %
- ☐ 4 – 60–79 %
- ☐ 5 – ≥ 80 %

6. Métricas temporales (MTTD, MTTC, MTTR)

T1. ¿La organización mide el tiempo medio de detección (MTTD) de eventos críticos, mapeados a ATT&CK?[web:26][web:60][web:64]

- ☐ 0
- ☐ 1 – No
- ☐ 2 – Sólo en análisis post-incidente
- ☐ 3 – Métricas globales de MTTD
- ☐ 4 – MTTD segmentado por táctica (p. ej., Initial Access, Credential Access, Lateral Movement)
- ☐ 5 – MTTD por técnica/subtécnica crítica, con objetivos definidos

T2. ¿Miden el tiempo medio de contención (MTTC) y recuperación (MTTR) para incidentes asociados a cadenas ATT&CK específicas (p. ej., ransomware, espionaje)?[web:66][web:43]

- ☐ 0
- ☐ 1 – No
- ☐ 2 – Sólo en grandes incidentes
- ☐ 3 – MTTC/MTTR globales
- ☐ 4 – MTTC/MTTR por tipo de amenaza (ransomware, BEC, etc.)
- ☐ 5 – MTTC/MTTR vinculados a rutas ATT&CK concretas y objetivos de servicio

T3. ¿Se emplean estos tiempos para justificar inversiones y cambios en la arquitectura de seguridad?

- ☐ 0
- ☐ 1 – No influyen en las decisiones
- ☐ 2 – Se mencionan en propuestas, sin trazabilidad clara
- ☐ 3 – Se utilizan como argumento en los business cases de seguridad
- ☐ 4 – Están integrados en análisis de coste-beneficio y priorización
- ☐ 5 – Se utilizan de forma sistemática para medir ROI de iniciativas ATT&CK-driven

7. Amenazas, CTI y MITRE ATT&CK

A1. ¿Se consume inteligencia de amenazas (CTI) que incluya mapeo de TTP a ATT&CK?[web:66][web:29]

- ☐ 0
- ☐ 1 – No
- ☐ 2 – Sólo informes ocasionales de proveedores
- ☐ 3 – Suscripciones regulares a CTI con referencias a ATT&CK
- ☐ 4 – CTI integrada en el SOC, con automatización básica
- ☐ 5 – CTI profundamente integrada, con actualización continua de casos de uso ATT&CK

A2. ¿Se han priorizado tácticas/técnicas en función del panorama de amenazas europeo/sectorial (p. ej., ENISA Threat Landscape 2025)?[web:66][web:43][web:63]

- ☐ 0
- ☐ 1 – No
- ☐ 2 – Se consideran de forma informal
- ☐ 3 – Existe un listado de TTP prioritarias para el sector
- ☐ 4 – TTP prioritarias integradas en roadmap de detección y controles
- ☐ 5 – Priorización revisada periódicamente según informes ENISA, CERT y sectoriales

A3. ¿Se realiza un mapeo entre incidentes reales sufridos por la organización y MITRE ATT&CK?

- ☐ 0
- ☐ 1 – No
- ☐ 2 – Sólo en incidentes graves
- ☐ 3 – En todos los incidentes de nivel medio/alto
- ☐ 4 – De forma sistemática, con estadísticas por táctica/técnica
- ☐ 5 – Integrado en informes ejecutivos y lecciones aprendidas

A4. En el último año, ¿qué tácticas ATT&CK han sido más frecuentes en incidentes reales? (respuesta múltiple)

- ☐ Initial Access
- ☐ Execution
- ☐ Persistence
- ☐ Privilege Escalation
- ☐ Defense Evasion
- ☐ Credential Access
- ☐ Discovery
- ☐ Lateral Movement
- ☐ Collection
- ☐ Command and Control
- ☐ Exfiltration
- ☐ Impact
- ☐ No disponemos de esta visibilidad

8. Integración con herramientas y procesos

I1. ¿Sus principales herramientas de seguridad (SIEM, EDR/XDR, NDR, SOAR, etc.) soportan referencias a MITRE ATT&CK de forma nativa?[web:16][web:65][web:23]

- ☐ 0
- ☐ 1 – No / desconocido
- ☐ 2 – Sólo algunas herramientas
- ☐ 3 – La mayoría de herramientas permite etiquetar o ver técnicas ATT&CK
- ☐ 4 – El SOC opera con paneles orientados por ATT&CK
- ☐ 5 – Todo el flujo de detección/investigación está alineado con ATT&CK

I2. ¿Se emplean dashboards o “heatmaps” ATT&CK para visualizar cobertura, eventos y brechas?

- ☐ 0
- ☐ 1 – No
- ☐ 2 – Prototipos o informes manuales
- ☐ 3 – Dashboard estable para el SOC
- ☐ 4 – Dashboard accesible a equipos técnicos y de gestión
- ☐ 5 – Panel integrado en reporting ejecutivo y planes de inversión

I3. ¿Existe un proceso definido para actualizar casos de uso cuando MITRE publica nuevas técnicas o revisa la matriz?

- ☐ 0
- ☐ 1 – No hay proceso
- ☐ 2 – Se revisa de forma reactiva
- ☐ 3 – Revisión periódica (p. ej., anual)
- ☐ 4 – Revisión programada vinculada a versiones de ATT&CK y CTI
- ☐ 5 – Proceso automatizado o semiautomatizado de revisión y priorización

9. Ejercicios, pruebas y mejora continua

E1. ¿Realiza la organización ejercicios de red teaming / purple teaming con mapeo explícito a ATT&CK?[web:16][web:22]

- ☐ 0
- ☐ 1 – No
- ☐ 2 – Ejercicios aislados sin mapeo formal
- ☐ 3 – Ejercicios con mapeo genérico a tácticas
- ☐ 4 – Ejercicios con mapeo a técnicas y evaluación de cobertura
- ☐ 5 – Programa continuo con métricas de mejora por técnica

E2. Tras un ejercicio o incidente, ¿se actualizan las métricas de cobertura ATT&CK (detección, tiempos, falsos positivos)?

- ☐ 0
- ☐ 1 – No
- ☐ 2 – Sólo en informes puntuales
- ☐ 3 – Actualización de métricas de forma recurrente

- [] 4 – Actualización integrada con backlog de ingeniería de detecciones
- [] 5 – Uso sistemático para re-priorizar inversiones y casos de uso

E3. ¿Se vinculan objetivos de mejora de cobertura ATT&CK a los objetivos anuales de los equipos (OKR/KPI)?

- [] 0
- [] 1 – No
- [] 2 – Sólo en el equipo de SOC
- [] 3 – En equipos clave (SOC, CTI, IR)
- [] 4 – Incluye responsables de negocio / dueños de activos críticos
- [] 5 – Forma parte de objetivos transversales de ciberresiliencia

10. Indicadores económicos: gasto, IGM y ROI

F1. ¿Existe un presupuesto específico vinculado a iniciativas (personas, procesos, tecnología) orientadas a mejorar métricas ATT&CK (cobertura, tiempos, calidad)?

- [] 0
- [] 1 – No, va “todo mezclado” en TI
- [] 2 – Parcialmente identificado
- [] 3 – Presupuesto específico para detección y respuesta
- [] 4 – Presupuesto etiquetado explícitamente con proyectos ATT&CK-driven
- [] 5 – Presupuesto trazable a métricas de cobertura y reducción de riesgo

F2. ¿Han estimado algún tipo de indicador global de madurez (IGM) basado en ATT&CK (p. ej., media ponderada de cobertura y tiempos)?

- [] 0
- [] 1 – No
- [] 2 – Estimaciones informales
- [] 3 – IGM básico calculado al menos anualmente
- [] 4 – IGM detallado con pesos por táctica / activo crítico
- [] 5 – IGM empleado en reporting interno y comparación interanual

F3. ¿Se calcula el ROI de iniciativas de mejora ligadas a ATT&CK (nuevas detecciones, automatizaciones, herramientas)?

- [] 0
- [] 1 – No
- [] 2 – Sólo para grandes proyectos
- [] 3 – ROI básico (antes/después) de iniciativas significativas
- [] 4 – Modelo de ROI recurrente para iniciativas de detección/IR
- [] 5 – ROI integrado en la evaluación de todas las iniciativas ATT&CK-driven

11. Cultura, formación y competencias

H1. ¿Se incluye MITRE ATT&CK en la formación del SOC y equipos técnicos?

- [] 0

- ☐ 1 – No
- ☐ 2 – Sólo a través de autoformación / cursos externos
- ☐ 3 – Plan de formación anual con contenidos ATT&CK
- ☐ 4 – Laboratorios y ejercicios prácticos con mapeo ATT&CK
- ☐ 5 – Formación continua, certificaciones internas y sesiones de intercambio

H2. ¿Se utiliza ATT&CK en la comunicación de incidentes a otros equipos (desarrollo, operaciones, negocio)?

- ☐ 0
- ☐ 1 – No, se habla “en dialecto técnico”
- ☐ 2 – De forma ocasional
- ☐ 3 – Mapeo sistemático de incidentes a tácticas en informes
- ☐ 4 – Se utiliza como lenguaje común con otras áreas técnicas
- ☐ 5 – Se ha introducido un “diccionario ATT&CK para no técnicos” y se usa en foros de riesgo

H3. ¿Existen roles formalmente responsables de la gestión de cobertura ATT&CK (p. ej., arquitecto de detección, ATT&CK owner)?

- ☐ 0
- ☐ 1 – No
- ☐ 2 – Responsabilidades difusas
- ☐ 3 – Rol identificado dentro del SOC
- ☐ 4 – Rol formal con mandato y objetivos de cobertura
- ☐ 5 – Estructura de gobierno con comité de detección y ATT&CK

12. Cierre

Cierre1. ¿Qué afirmación describe mejor la actitud de su organización hacia MITRE ATT&CK?

- ☐ Es un póster bonito y poco más
- ☐ Es una referencia ocasional para análisis de incidentes
- ☐ Es una guía útil para el SOC
- ☐ Es un eje central de la detección y respuesta
- ☐ Es parte de la forma en que medimos y gobernamos el riesgo

Cierre2. Comentarios adicionales, confesiones, epifanías o críticas constructivas: